

FINAL-YEAR PROJECT PROPOSAL

# Detecting Blockchain-Anchored Command-and-Control in IoT Botnets

*A defensive measurement and detection study of ENS/SNS-based C2 and victim-relay meshes, using the Dysphoria / JackSkid lineage as a driving case*

**Prepared by: Shivraj**

Programme: B.E. / B.Tech Final-Year Project

Proposed target: peer-reviewed conference / workshop paper

Date: July 2026

## 1. Abstract

IoT botnets have long depended on a small number of hard-coded command-and-control (C2) servers, which makes them vulnerable to coordinated takedowns. The Dysphoria botnet line — analysed by CNCERT and XLab and reported in July 2026 — demonstrates a decisive shift in this arms race. After a March 2026 law-enforcement operation disrupted its predecessor JackSkid, the operators re-anchored their C2 in decentralised blockchain name services (Ethereum Name Service, ENS, and Solana Name Service, SNS) and built a traffic-relay mesh out of infected victim devices, deliberately keeping the true controllers one hop removed from the addresses exposed to bots. Because blockchain records cannot easily be seized or blocked, conventional server-seizure defences are substantially weakened.

This project proposes a defensive study that (i) characterises how blockchain-anchored C2 and victim-relay meshes work across the JackSkid / Dysphoria / Kimwolf lineage, and (ii) designs and evaluates a detection method that identifies devices resolving C2 through blockchain name services and participating in relay behaviour, using only observable network and host indicators. All experimentation is performed on public malware samples, public threat-intelligence telemetry, and an isolated laboratory testbed; no live attack infrastructure is created or operated. The intended contribution is a reproducible detection pipeline plus an open, labelled indicator dataset suitable for publication at a student-accessible security venue.

## 2. Problem Statement and Motivation

The economic value of an IoT botnet is proportional to how long it survives. Defenders' most effective weapon has historically been infrastructure seizure: identify the C2 servers, obtain court orders, and sinkhole or take them offline. The March 19, 2026 coordinated action by U.S., German, and Canadian authorities — which targeted four IoT botnets including JackSkid, to which court documents attributed more than 90,000 DDoS commands — is a textbook example of this approach.

The motivating problem is that this defence is now being systematically neutralised. Within six days of the JackSkid takedown, a captured sample (March 25, 2026) resolved its C2 through an ENS domain (m3rnbvs5d[.]eth). Subsequent builds added custom RC4 string encryption and ENS resolution (late April), Solana Name Service resolution (early May), a relay-only variant (June 25), and UPnP-based NAT traversal days later. **The design keeps the real controllers hidden behind blockchain-published distribution nodes and victim relays, so seizing any single server no longer decapitates the botnet.**

This creates an urgent and currently open detection gap. If infrastructure cannot be removed, defenders must instead detect participation early — at the endpoint or the network edge — before a device is drawn into DDoS or relay activity. Yet blockchain-anchored resolution does not look like the classic hard-coded IP or DGA-domain behaviour that most existing detectors are tuned for. A device querying a public blockchain resolver or an ENS/SNS gateway can appear superficially benign. This project targets exactly that gap.

## 3. Background

### 3.1 IoT botnet C2 evolution

Since Mirai (2016), the dominant IoT botnet model has been: compromise poorly secured devices via weak Telnet/SSH credentials or known remote-code-execution (RCE) flaws, receive orders from a C2 server, and

launch distributed denial-of-service (DDoS) attacks. Defenders responded with sinkholing, DGA reverse-engineering, and infrastructure seizure. Attackers responded with domain-generation algorithms, fast-flux DNS, and — most recently — decentralised name services.

### 3.2 Blockchain name services as a C2 channel

Ethereum Name Service (ENS) and Solana Name Service (SNS) map human-readable names (e.g., burrberry[.]eth) to arbitrary records stored on a public blockchain. Because these records are globally replicated and censorship-resistant, an attacker can publish the current location of distribution infrastructure in a place no single authority can delete. In the Dysphoria case, the burrberry[.]eth record encodes distribution-node IPv4 addresses, while 24carnforth2merseyside[.]sol supplies further infrastructure records. A bot resolves the name, contacts a distribution node over HTTP for a current server list, and is pointed at infected relays rather than at the real controllers.

### 3.3 Victim-relay mesh and NAT traversal

The June 2026 relay-only variant drops the DDoS modules entirely and instead uses UPnP to map ports on the local gateway and Linux epoll to shuttle traffic between an inbound connection and a remote C2 service. In effect, ordinary compromised home and small-office devices become proxy hops that shield the operator. This is the same ENS-based resolution model previously documented in the related Kimwolf botnet (late 2025), now coupled with a relay mesh built from the botnet's own victims.

**Important measurement caveat.** The reported scale — a population above 200,000 bots, a single-day peak of 239,000 abroad, and a ~4 Tbps storefront claim — has not been independently reproduced, and the researchers published no de-duplication methodology. Any project that cites these figures must present them as unverified operator/vendor claims, not as measured ground truth. This proposal treats scale claims accordingly.

## 4. Research Gap and Novelty

Prior academic work on botnet detection concentrates on hard-coded IP C2, DGA domains, and peer-to-peer botnets. Blockchain-anchored C2 is comparatively under-studied in the open literature, and most existing coverage of Dysphoria/JackSkid is industry threat-intelligence reporting rather than reproducible, evaluated detection research. The novelty of this project rests on three points:

- It focuses detection on the resolution step — the moment a device consults a blockchain name service or ENS/SNS gateway for C2 records — rather than on the DDoS step, enabling earlier detection.
- It treats the victim-relay mesh as a first-class detectable behaviour (UPnP port-mapping plus epoll-style bidirectional relaying), not merely as background noise.
- It produces an open, labelled indicator dataset and a reproducible pipeline, addressing the reproducibility gap in current vendor reporting.

This scope is deliberately defensive and self-contained, which makes it both ethically clean and realistically achievable for a final-year timeline at a moderate engineering skill level.

## 4.1 Positioning against existing IoT-botnet detection work

A large body of prior work already detects IoT botnets — mostly Mirai and its variants — using machine learning on public datasets (N-BaloT, Bot-IoT, IoT-23). A reviewer will immediately ask how this project differs. The distinction is the detection target: **existing detectors fingerprint the attack stage (DDoS floods, scanning, infection) or hard-coded/DGA C2, whereas this project detects the blockchain-anchored C2 resolution and victim-relay stage — a signal that did not exist in the traffic before late 2025 and that defeats the takedown-based defences prior work implicitly assumes.** The central, falsifiable claim of the paper is therefore: resolution- and relay-stage indicators add detection value that attack-stage features alone do not provide. The ablation study (Section 7) is designed specifically to prove or disprove this claim.

*Note on literature verification: because this botnet was reported in July 2026, a targeted search of Google Scholar / IEEE Xplore / arXiv for "blockchain C2 botnet detection" and "ENS/SNS command-and-control detection" should be run before submission to confirm the gap and to cite any concurrent work. If the resolution angle is already taken, the victim-relay detection (Section 4.2) is an even newer fallback contribution.*

## 4.2 Advanced features that strengthen the contribution

Beyond the baseline detection pipeline, the following features each constitute a distinct research contribution and are what elevate the work from a routine classifier to a selectable paper. The two marked (core) are the primary novelty; the remainder add rigor.

- Blockchain-resolution fingerprinting (core): characterise how ENS/SNS lookups and the subsequent HTTP server-list pull differ from benign Web3 / blockchain traffic (resolver endpoints, query timing, record-pull pattern). This specific profiling is largely unstudied.
- Victim-relay detection (core): a dedicated detector for devices turned into proxy hops (UPnP AddPortMapping plus epoll-style bidirectional relaying). The relay-only variant is the newest behaviour in the lineage and the least studied.
- Concept-drift / temporal evaluation: train on an earlier malware build and test on a later one to measure detector decay as the family evolves — the security analogue of the reference paper's covariate-shift analysis.
- Adversarial robustness: test whether simple evasions (jittered beacon timing, packet padding) degrade detection, demonstrating the method's resilience and maturity.
- Early-detection metric: measure how far in advance of the DDoS/relay stage a device can be flagged (in seconds or packets) — a headline, deployment-relevant result.
- Edge/real-time feasibility: report inference latency and memory footprint and argue the detector can run on a home router or gateway, turning a lab study into a deployable defence.

# 5. Research Questions and Objectives

## 5.1 Research questions

1. RQ1: What observable network and host indicators distinguish a device resolving C2 through blockchain name services (ENS/SNS) from benign use of the same resolvers?
2. RQ2: Can victim-relay behaviour (UPnP port mapping plus bidirectional traffic relaying) be detected reliably at the network edge without host access?

3. RQ3: How well does a lightweight detection model built on these indicators generalise across the JackSkid / Dysphoria / Kimwolf lineage, and where does it fail?

## 5.2 Objectives

| #  | Objective                                                                                              | Success criterion                                                                                    |
|----|--------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------|
| O1 | Characterise the C2 resolution and relay mechanisms across the lineage from public reports and samples | A documented, cited technical taxonomy with an attack/kill-chain diagram                             |
| O2 | Build an isolated testbed that safely reproduces blockchain-name resolution and relay traffic patterns | Reproducible lab that emits labelled benign vs. suspicious traces with no external attack capability |
| O3 | Design a detection method (heuristics + ML) over network/host indicators                               | Documented feature set and model with an ablation study                                              |
| O4 | Evaluate detection accuracy and generalisation                                                         | Precision/recall/F1, ROC-AUC, and false-positive analysis on held-out traces                         |
| O5 | Release an open indicator dataset and pipeline                                                         | Public, documented artifact with a reproducibility README                                            |

## 6. Related Work

The project situates itself against three bodies of work. First, classical IoT botnet studies (Mirai and its many descendants) establish the weak-credential / known-RCE infection model and the DDoS objective. Second, C2-resilience research covers DGAs, fast-flux, and peer-to-peer botnets, from which blockchain name services are the logical next step. Third, recent industry reporting — Nokia Deepfield and Comcast on the JackSkid-to-ENS fallback, XLab's Dysphoria timeline, Japan's NICT independent confirmation of the ENS/SNS shift, and Cloudflare's DDoS measurements of the related AISURU/Kimwolf botnet — provides the primary source material. A recurring finding across NICT, Nokia, and Comcast is shared code and strings across several families, which points to shared tooling rather than a single attributed operator; the project therefore studies techniques, not attribution.

## 7. Proposed Methodology

### 7.1 System overview

The detection pipeline has four stages: (1) trace collection from the isolated testbed and from public capture datasets; (2) feature extraction focused on resolution and relay indicators; (3) a two-tier detector combining explainable heuristics with a supervised classifier; and (4) evaluation against held-out and cross-family traces.

### 7.2 Candidate detection indicators

| Category   | Example indicators                                                                                             | Rationale                                                                   |
|------------|----------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------|
| Resolution | Queries to ENS/SNS gateways or public blockchain RPC endpoints; HTTP pulls of a 'server list' after resolution | Captures the moment a bot fetches C2 records from a blockchain name service |

|           |                                                                                                            |                                                          |
|-----------|------------------------------------------------------------------------------------------------------------|----------------------------------------------------------|
| Relay     | UPnP AddPortMapping requests on the local gateway; long-lived bidirectional flows with epoll-style fan-out | Identifies victim devices acting as proxy hops           |
| Infection | Telnet/SSH login bursts against the device; scan patterns; known IoT RCE signatures                        | Detects the entry vector (weak credentials / known CVEs) |
| Payload   | Custom RC4-encrypted strings; small periodic beacons                                                       | Distinguishes malware traffic from benign IoT chatter    |

### 7.3 Data sources (ethically obtained)

- Public malware sample repositories and published IOCs from the cited CNCERT/XLab/NICT/Nokia/Comcast reports (for static characterisation only).
- Isolated-testbed captures generated by the student, fully air-gapped from the public internet's attack surface.
- Public benign IoT traffic datasets (e.g., academic IoT-traffic corpora) to model the negative class and measure false positives.

### 7.4 Detection model

A transparent baseline (rule-based heuristics on the indicators above) is compared against a supervised classifier (e.g., gradient-boosted trees or a compact random forest) chosen for interpretability and low compute — appropriate for a moderate skill level and for potential edge deployment. An ablation study quantifies each indicator group's contribution, which strengthens the paper's analytical contribution.

## 8. Experimental Setup and Testbed

All dynamic experimentation runs inside a virtualised, network-isolated lab: emulated IoT devices (e.g., QEMU/OpenWrt images), a local stand-in name resolver that mimics ENS/SNS lookups without touching real blockchains, and a controlled relay node. This lets the project reproduce the observable traffic shapes (resolution query, server-list pull, UPnP mapping, bidirectional relay) for labelling purposes, while guaranteeing that no functional attack tool, live C2, or outbound DDoS capability is ever created. The testbed design and its containment controls are themselves a documented contribution.

## 9. Ethical, Legal, and Safety Considerations

- No offensive capability: the project never builds, improves, or operates a working botnet, C2, or DDoS tool. Malware samples are handled statically or in a contained sandbox for analysis only.
- Containment: all dynamic analysis is air-gapped/virtualised; the relay and resolver are local stand-ins, so no traffic can reach third parties.
- Responsible use of data: only public IOCs and public/academic datasets are used; no scanning of live third-party devices and no interaction with real attacker infrastructure.
- Attribution restraint: consistent with the primary sources, the project studies techniques and does not name or accuse any operator.
- Institutional approval: the plan will be reviewed by the project supervisor and, where required, the department ethics/lab-safety process before any dynamic work begins.

## 10. Evaluation Plan

Detection performance is reported with precision, recall, F1, and ROC-AUC, plus a dedicated false-positive analysis against benign IoT traffic (the practical barrier to deployment). Generalisation is tested by training on one family's traces and testing on another's within the lineage. Runtime cost (CPU/memory) is measured to assess edge feasibility. The heuristic baseline and the ML model are compared head-to-head, and the ablation study isolates the value of the blockchain-resolution indicators specifically — the paper's central claim.

## 11. Expected Contributions

4. A cited technical taxonomy of blockchain-anchored C2 and victim-relay meshes across the JackSkid/Dysphoria/Kimwolf lineage.
5. A reproducible, containment-safe testbed for generating labelled traces of these behaviours.
6. A detection method with an ablation study isolating the contribution of blockchain-resolution indicators.
7. An open, labelled indicator dataset and pipeline addressing the reproducibility gap in current vendor reporting.

## 12. Publication Strategy

The work is scoped to be publishable at a student-accessible venue. Realistic targets, in rough order of accessibility, include undergraduate/student research tracks and workshops, then regional and mid-tier security conferences. A short 'systematization + small evaluation' framing is the most reliable route to acceptance for a first paper; a strong evaluation can then justify a fuller submission.

| Venue type                      | Examples of fit                                                                               | Notes                                                    |
|---------------------------------|-----------------------------------------------------------------------------------------------|----------------------------------------------------------|
| Student / workshop tracks       | IEEE/ACM student research competitions; security workshops co-located with larger conferences | Most accessible; good for a first paper and feedback     |
| Regional / national conferences | Regional IEEE conferences; national cybersecurity symposia                                    | Higher visibility; expect a full evaluation              |
| Preprint + artifact             | arXiv preprint with a public dataset/code release                                             | Establishes priority and lets others reproduce your work |

**Note:** confirm current venue names, deadlines, and scope with your supervisor before committing — venue details change year to year, and this proposal was written from a July 2026 snapshot.

## 13. Project Timeline

An indicative plan across a typical two-semester final-year schedule. Adjust to your institution's dates.

| Phase                 | Duration   | Key deliverables                                        |
|-----------------------|------------|---------------------------------------------------------|
| Literature & scoping  | Weeks 1–4  | Related-work review; finalized RQs; ethics/lab approval |
| Characterisation (O1) | Weeks 4–7  | Technical taxonomy; kill-chain diagram; IOC catalogue   |
| Testbed build (O2)    | Weeks 7–12 | Isolated lab; labelled trace                            |

|                       |             |                                                |
|-----------------------|-------------|------------------------------------------------|
|                       |             | generation                                     |
| Detection design (O3) | Weeks 11–16 | Feature set; heuristic baseline; ML model      |
| Evaluation (O4)       | Weeks 16–21 | Metrics, ablation, generalisation, FP analysis |
| Artifact & paper (O5) | Weeks 20–26 | Open dataset/pipeline; paper draft; submission |

## 14. Risk Assessment and Mitigation

| Risk                                          | Likelihood | Mitigation                                                                                   |
|-----------------------------------------------|------------|----------------------------------------------------------------------------------------------|
| Scarce ground-truth traces for a new family   | High       | Generate labelled data in the testbed; use public IOCs; frame as few-shot/heuristic-assisted |
| High false positives from benign resolver use | Medium     | Dedicated FP analysis; combine resolution + relay indicators before alerting                 |
| Scope creep into offensive territory          | Medium     | Hard ethical boundary: analysis/detection only; supervisor sign-off                          |
| Unverifiable scale/impact claims              | High       | Cite as vendor/operator claims; do not present as measured results                           |
| Sample handling / containment failure         | Low        | Air-gapped VMs; local resolver/relay stand-ins; no live infrastructure                       |

## 15. References (starting set)

*Formatted informally; convert to your required citation style. Verify each link before submission.*

- [1] S. Khandelwal, "Dysphoria IoT Botnet Adds Blockchain C2 and Victim Relays After JackSkid Disruption," The Hacker News, Jul. 27, 2026.
- [2] XLab (Qi'anxin), "Dysphoria" analysis, [blog.xlab.qianxin.com/dysphoria/](https://blog.xlab.qianxin.com/dysphoria/), Jul. 25, 2026.
- [3] CNCERT, joint Dysphoria notice (mirrored at [secrss.com/articles/92461](https://secrss.com/articles/92461)), 2026.
- [4] Nokia Deepfield & Comcast threat lab, JackSkid ENS fallback report, [github.com/deepfield/public-research/blob/main/jackskid/report.md](https://github.com/deepfield/public-research/blob/main/jackskid/report.md), 2026.
- [5] NICT (Japan), "JackSkid-to-ENS/SNS shift," [blog.nicter.jp](https://blog.nicter.jp), May 2026.
- [6] The Hacker News, "DoJ Disrupts 3-Million-Device IoT Botnet," Mar. 2026 (JackSkid takedown).
- [7] The Hacker News, "Kimwolf Botnet Hijacks 1.8M Devices," Dec. 2025 (ENS-based C2).
- [8] Cloudflare, "DDoS Threat Report 2025 Q4," (31.4 Tbps AISURU/Kimwolf measurement).
- [9] NVD, CVE-2025-9528, Linksys E1700 command injection, disclosed Aug. 2025.
- [10] M. Antonakakis et al., "Understanding the Mirai Botnet," USENIX Security, 2017.
- [+] Add: ENS/SNS technical documentation; academic surveys on DGA/fast-flux and P2P botnet detection; public IoT benign-traffic datasets used for your negative class.